

CAMS Exam Preparation

Part C: Building an Anti-Financial Crime Compliance Program (30% of Exam)

Advanced AML Training Framework

Domain C: 30 percent of CAMS Exam — Governance, Risk Assessment, CDD, Training, Independent Testing, Investigations

Core Concept

A foundational governance model ensuring separation between risk-taking, risk oversight, and independent assurance.

Line	Who	Primary Role
First Line	Business ops, RMs, tellers, loan officers	Own and manage risk; identify anomalies; complete initial CDD; escalate to compliance
Second Line	Compliance Dept, BSA Officer, MLRO	Oversee risk; set rules; monitor First Line; investigate; file SARs
Third Line	Internal Audit, external auditors	Independent assurance; audit First and Second Lines; report to Board

[RED FLAG: Golden Rule: No single line should both DESIGN and TEST the same controls.]

[FOCUS] Exam tests whether you can identify independence violations across all three lines.

First Line (Business Operations) - What They MUST Do

The First Line is the front door of AML defense. They interact with customers directly.

Specific Duties:

- Complete initial CIP
- Assess expected activity profile
- Identify unusual transactions
- Escalate concerns to compliance
- Respond to compliance RFIs
- Maintain customer records
- Update changes in customer status

Common Red Flags to Spot:

- Reluctance to provide ID
- Unusual transaction patterns
- Structuring cash deposits
- Changes without explanation
- Inconsistent narratives
- Third-party transactions
- Reluctance to explain source

[RED FLAG: Critical: First Line cannot close alerts or make SAR decisions. That is Second Line authority.]

[SCENARIO] RM Tells Analyst to Close Alert Based on Personal Knowledge A relationship manager has known a corporate client for 12 years. The client suddenly makes weekly cash deposits of \$9,500 - just below the \$10,000 CTR threshold. The RM tells compliance: I have known this customer for over a decade. He is trustworthy. Just close the alert.

How to Analyze:

- 1 First Line's job: IDENTIFY and ESCALATE - not investigate or close
- 2 Second Line's job: INVESTIGATE independently
- 3 The deposit pattern (\$9,500 weekly) is structuring
- 4 Closing without documentation violates AML program requirements

[TRAP] RM's long relationship is NOT sufficient evidence to close an alert. [CORRECT]
Compliance must conduct independent investigation with documented evidence.

Second Line (Compliance) - Core Duties

The Second Line must operate independently from the First Line and have authority to override business decisions.

Core Duties:

- Design AML policies
- Conduct transaction monitoring
- Investigate alerts
- Make SAR filing decisions
- File SARs with FIU
- Provide training
- Conduct EDD
- Maintain risk assessment
- Respond to law enforcement
- Report to Board

Independence Requirements:

- Cannot report to business lines
- Direct Board access
- Override business decisions
- Sufficient staffing
- No commercial pressure
- Access to all information
- Independent budget

[RED FLAG: Commercial importance of a client is NEVER a valid reason to delay or avoid SAR filing.]

[SCENARIO] Analyst Closes Alert Without Investigation An analyst reviews an alert for a restaurant customer with 23 cash deposits between \$8,400 and \$9,800 over 45 days. The analyst writes: Restaurant business. Cash is normal. No SAR needed.

How to Analyze:

- 1 23 deposits just below \$10,000 = structuring indicator
- 2 Structuring is a federal crime regardless of funds origin
- 3 The analyst assumed legitimacy without verification
- 4 No documentation = no investigation occurred

[TRAP] Analyst used reasonable business judgment based on industry. [CORRECT] Analysts must obtain supporting documentation and document all investigative steps. Assumptions are not investigations.

Internal Audit - What They CAN and CANNOT Do

Audit independence is absolutely critical to program credibility.

Audit CAN Do	Audit CANNOT Do
Test effectiveness of controls	Design or build controls
Recommend improvements	Operate monitoring systems
Report findings to Board	Make SAR decisions
Review sample of alerts	Approve customer relationships
Assess policy compliance	Perform ongoing monitoring
Evaluate training	Conduct EDD on customers

[RED FLAG: Most Common Violation: Audit helping to design scenarios THEN auditing those same scenarios.]

[SCENARIO] Audit Designs Controls Then Tests Them Compliance lacks technical expertise. CCO asks Internal Audit for help. Audit spends 3 months co-designing 14 new monitoring scenarios. Six months later, the same audit team tests the system and finds all 14 scenarios effective.

How to Analyze:

- 1 Audit's role is to TEST, not DESIGN
- 2 Designing controls makes Audit part of Second Line
- 3 Auditors cannot objectively test their own work
- 4 The audit findings are unreliable

[TRAP] Scenarios were effective, so no violation. [CORRECT] Audit must remain independent. Use external consultants or different internal team with no design involvement.

Board Oversight - Ultimate Accountability

The Board is ultimately accountable for the AML program. Regulators hold the Board responsible.

Board MUST:

- Approve initial AML program
- Approve material changes
- Appoint BSA Officer
- Receive regular updates
- Be informed of deficiencies
- Hold management accountable
- Review audit findings
- Ensure adequate resources

Board DOES NOT:

- File SARs
- Review KYC files
- Monitor daily alerts
- Conduct investigations
- Make SAR decisions
- Perform testing
- Approve transactions

[RED FLAG: Board approval is required for the AML program. CCO cannot approve their own program.]

[SCENARIO] Management Withholds Information from Board Compliance discovers a 14-month monitoring gap affecting \$340 million in wires. Senior management decides not to inform the Board because the issue is operational and will be fixed within 90 days.

How to Analyze:

- 1 14-month gap affecting \$340 million is MATERIAL
- 2 Material deficiencies MUST be reported to Board immediately
- 3 Management cannot filter or delay reporting
- 4 Board needs this information for oversight

[TRAP] Senior management has authority to decide what reaches the Board. [CORRECT] Board must be informed of material deficiencies. Management cannot withhold this information.

[SCENARIO] CCO Implements Policy Without Board Approval CCO drafts revised AML policy. Legal reviews and approves. CCO implements without presenting to Board. CCO argues: I am the designated BSA Officer with authority to implement policies. Board approval is unnecessary.

How to Analyze:

- ① Board must approve AML program under BSA
- ② Material changes require Board approval
- ③ CCO implements, does not have final approval
- ④ Policy is not effective without Board approval

[TRAP] CCO has delegated authority to implement policies. [CORRECT] Board must approve AML program and material changes. CCO implements Board-approved program but lacks final approval authority.

Senior Management - Execution and Accountability

Senior management executes the Board-approved program and is accountable to the Board.

Senior Management MUST:

- Implement Board-approved program
- Allocate sufficient resources
- Ensure timely SAR filings
- Respond to audit findings
- Report material issues to Board
- Appoint qualified staff
- Ensure training effectiveness

Senior Management CANNOT:

- Veto SARs for commercial reasons
- Withhold information from Board
- Retaliate against whistleblowers
- Operate without Board approval
- Delegate accountability
- Ignore audit findings

[RED FLAG: Senior management faces personal regulatory risk for AML failures, including fines and imprisonment.]

Written Policies, Procedures, and Controls

The BSA/AML compliance program must be reduced to writing and approved by the Board.

Mandatory Governance Documents:

- Written AML/CFT Policy approved by Board (initial and all material changes)
- Written CIP (Customer Identification Program) procedures
- Written CDD/EDD procedures (including beneficial ownership)
- Written SAR filing procedures (internal decision-making, timeliness)
- Written independent testing procedures and scope
- Written employee training program (role-based curriculum)
- Written risk assessment methodology (Enterprise-Wide Risk Assessment)
- Written escalation procedures (compliance to management to Board)
- Written recordkeeping procedures (retention periods, secure storage)

[RED FLAG: Verbal policy or unwritten procedure does NOT satisfy regulatory requirements.]

[SCENARIO] Board Verbally Approves AML Policy Without Minutes Board chair verbally approves updated AML policy during meeting. Secretary does not record vote or discussion in minutes.

How to Analyze:

- 1 Unwritten approval is insufficient — approval must be documented in minutes
- 2 Minutes must show evidence of meaningful oversight, not rubber-stamping
- 3 Discussion of AML risks, resource allocation, and key metrics must appear
- 4 Regulators will treat missing minutes as evidence of Board non-engagement

[TRAP] Verbal approval is still approval; minutes are administrative formality. [CORRECT]
Board minutes must document AML approval, discussion, and ongoing oversight.

CCO Reporting Line and Authority

The CCO/BSA Officer must have sufficient authority, independence, and resources.

Required Attributes:

- Direct reporting access to Board or Board Committee (not filtered by business lines)
- Authority to allocate resources (staff, technology, training)
- Authority to override business decisions regarding customer relationships
- No reporting line to revenue-generating functions
- Sufficient seniority to influence decisions
- Protection from retaliation for exercising duties

Red Flags for Independence Violation:

- CCO reports to Head of Retail Banking (revenue function)
- Business lines control CCO's budget
- CCO is removed after filing SAR on high-revenue client
- CCO position is vacant for extended period
- Same person serves as CCO and Head of Sales

[RED FLAG: If CCO can be overridden by business lines for commercial reasons, CCO lacks required authority.]

[SCENARIO] CCO Reports to Head of International Banking (Revenue) Bank's CCO reporting line is to Head of International Banking, who is compensated based on revenue growth. Head instructs CCO to delay SAR filing on large corporate client because client is negotiating a \$50 million credit facility.

How to Analyze:

- 1 CCO must report to Board or independent committee, not revenue-generating management
- 2 Revenue pressure on CCO compromises independence
- 3 Delaying SAR for commercial reasons is a regulatory violation
- 4 Budget reduction following SAR filings suggests retaliation

[TRAP] Reporting to senior management is acceptable as long as CCO has Board access.

[CORRECT] CCO must report to independent authority without revenue conflicts.

Adequate Resources = Regulatory Requirement

Institutions must provide AML compliance with sufficient resources.

Resource Areas Requiring Adequacy:

- Staffing: Sufficient analysts to review all alerts within required timeframes
- Technology: Monitoring systems, screening tools, case management, data infrastructure
- Training: Ongoing, role-based training for compliance and business staff
- External support: Legal, audit, third-party consultants as needed
- Budget: Competitive salaries to retain qualified talent

Evidence of Resource Inadequacy:

- Persistent backlog of uninvestigated alerts (thousands aging >30 days)
- High analyst turnover (burnout, underpaid, under-supported)
- Manual processes for high-volume tasks that could be automated
- Delayed SAR filings due to insufficient reviewers
- Board rejects reasonable budget requests from CCO
- Staff not qualified for assigned duties

[RED FLAG: Under-resourcing is NOT a defense. Regulators will cite inadequate resources as a violation.]

Risk Assessment as the Foundation

The AML program must be based on a documented, comprehensive risk assessment.

Required Risk Factors (Must Address All):

- Products and services offered
- Customer types and segments
- Geographic locations (operations and customer base)
- Delivery channels (online, branch, mobile, agents)
- Transaction volumes and values
- Jurisdictions with weak AML regimes
- Politically Exposed Persons (PEPs)
- Non-profit organization exposure
- Correspondent banking relationships
- Private banking relationships
- Emerging technologies (crypto, etc.)
- Previous regulatory findings

Risk Assessment Outputs:

- Inherent risk score (risk without controls)
- Control effectiveness rating
- Residual risk score (risk after controls)
- Action plan for residual risks exceeding tolerance

[RED FLAG: EWRA must be UPDATED at least annually or after material changes.]

[SCENARIO] Bank Has High Inherent Risk But Strong Controls Bank serves high-risk customers (MSBs, NPOs in conflict zones) and operates in high-risk jurisdictions (inherent risk = 8/10). Bank has strong controls: dedicated EDD team, transaction monitoring with low false negatives, monthly Board reporting (control effectiveness = 9/10). Residual risk = 3/10.

How to Analyze:

- 1 High inherent risk does NOT automatically mean deficient program
- 2 Strong controls can reduce residual risk to acceptable levels
- 3 Bank must document both inherent and residual risk
- 4 Regulator will test whether controls are as strong as claimed

[TRAP] High inherent risk is always unacceptable regardless of controls. [CORRECT]
Risk-based approach accepts higher inherent risk if controls are proportionate and effective.

Quantitative Risk Assessment

Many institutions use numerical scores to determine risk categories.

Typical Risk Scoring Model:

- Each risk factor (geography, customer type, product/service) scored 1-10
- 1-3 = Standard/Low Risk
- 4-8 = Medium Risk
- 9-10 = High Risk
- Composite score = sum or weighted average of all factors

Weighting Considerations:

- Some factors may be weighted more heavily (e.g., customer type vs. geography)
- Combinations can change risk dramatically (e.g., foreign private company + wire transfer capability)
- High-risk relationships should not represent too large a segment of portfolio

Review Frequency:

- At least annually
- Before launching new products
- After acquisition of another institution
- When material changes occur

Risk is Not Static - Must Be Continuously Managed

A customer's risk rating may change based on actual activity.

Triggers for Risk Rating Change:

- Unusual activity (alerts, cases, SAR filings)
- Receipt of law enforcement inquiries (subpoenas)
- Transactions that violate economic sanctions
- Significant changes in transaction volume or pattern
- New information about customer (negative media, change in ownership)
- Customer begins using higher-risk products or services

Example:

- Student checking account = low inherent risk
- But if account shows large wires to high-risk jurisdictions = raise risk rating
- Conversely, MSB with high inherent risk may have normal activity = lower residual risk

[RED FLAG: Document ALL risk rating changes with rationale.]

FATF Recommendation 10 - Core CDD Measures

Financial institutions must conduct CDD when establishing business relationships or when suspicion arises.

Four Required CDD Elements:

- 1 Identify the customer and verify identity using reliable, independent source documents
- 2 Identify the beneficial owner and take reasonable measures to verify identity
- 3 Understand and obtain information on purpose and intended nature of relationship
- 4 Conduct ongoing due diligence and scrutiny of transactions to ensure consistency with knowledge of customer, business, and risk profile

When CDD MUST Be Performed:

- Establishing business relationships
- Carrying out occasional transactions above threshold
- Suspicion of money laundering or terrorist financing
- Doubts about veracity of previously obtained identification

[RED FLAG: Anonymous or fictitious name accounts are PROHIBITED.]

Beneficial Owner Definition

The natural person who ultimately owns or controls a customer and/or the natural person on whose behalf a transaction is conducted.

Verification Requirements for Legal Persons:

- Identify natural persons with significant ownership (typically 25% or more)
- Identify natural persons with ultimate effective control
- Understand ownership and control structure
- Use reliable, independent sources (corporate registers, commercial databases)
- Do NOT rely solely on written declarations from customer

For Trusts and Similar Arrangements:

- Identify settlor, trustee, protector (if any), beneficiaries, and any other natural person exercising control

When CDD Cannot Be Performed:

- Do NOT open account (or close opened accounts)
- Consider reporting suspicious activity to authorities

When Standard CDD Is Not Enough

Higher risk circumstances require enhanced measures.

Customer Risk Factors Requiring EDD:

- Non-resident customers
- Legal persons with nominee shareholders or bearer shares
- Cash-intensive businesses
- Unusually complex ownership structures
- PEPs (foreign and domestic)

Geographic Risk Factors Requiring EDD:

- Countries with inadequate AML/CFT systems (FATF lists)
- Countries subject to sanctions or embargoes
- Countries with significant corruption or criminal activity
- Countries providing funding/support for terrorism

Product/Service Risk Factors:

- Private banking
- Anonymous transactions (cash, prepaid cards)
- Non-face-to-face relationships
- Payments from unknown third parties

Enhanced Due Diligence Controls

Institutions must apply stronger controls for higher risk relationships.

Additional Information to Obtain:

- Source of funds and wealth (documented)
- Identifying information on individuals with control (signatories, guarantors)
- Financial statements (audited, if available)
- Banking references
- Description of business operations and expected transaction volume
- Explanations for changes in account activity

Required Controls for EDD:

- Senior management approval to commence or continue relationship
- First payment through account in customer's name at bank with similar CDD standards
- More frequent monitoring and review of account activity
- Periodic re-verification of customer information

FATF Definition - Two Types of PEPs

Individuals entrusted with prominent public functions.

Foreign PEPs:

- Heads of state or government
- Senior politicians, government, judicial, military officials
- Senior executives of state-owned corporations
- Important political party officials
- Includes family members and close associates

Domestic PEPs:

- Same categories but within the institution's own country
- EU Fourth Directive explicitly covers domestic PEPs

Required Measures for PEPs:

- Identify PEP status before or during relationship
- Senior management approval for relationship
- Establish source of wealth and source of funds
- Enhanced ongoing monitoring

[RED FLAG: PEP designation does NOT end when they leave office. Enhanced monitoring typically continues for 12-24 months after position ends.]

Natural Persons - Information to Collect

Basel Committee General Guide to Account Opening.

Required Information:

- Legal name and any other names used (maiden name, alias)
- Complete residential address (and business address or PO box based on risk)
- Telephone numbers and email address
- Date and place of birth, gender
- Nationality and residency status
- Occupation, position held, name of employer
- Official personal identification number
- Type of account and nature of relationship
- Signature

Verification Methods:

- Documentary: unexpired official document with photo, official document for date/place of birth
- Non-documentary: telephone contact, references from other institutions, public registers, commercial databases

Information to Obtain for Legal Persons/Arrangements

Entities require additional due diligence beyond natural persons.

Required Information:

- Name, legal form, status, proof of incorporation
- Permanent address of principal place of activities
- Mailing and registered address
- Identity of natural persons authorized to operate account
- Official identification number
- Powers that regulate and bind the legal person
- Identity of beneficial owners
- Nature and purpose of activities
- Financial situation of entity
- Expected use of account (amount, number, type, purpose, frequency)

Verification Methods:

- Certificate of incorporation, memorandum and articles
- Financial statements (audited if available)
- Company search, commercial inquiries
- Prior bank references
- Visit corporate entity where practical

Fragmented CDD = Increased Risk

A fragmented CDD program significantly increases ML/TF risk.

Key Principles of Consolidated CDD:

- Consistent identification and monitoring across business lines globally
- Parent-level oversight to capture unusual patterns across subsidiaries
- Apply minimum CDD standards to all offices, branches, subsidiaries
- When home and host country standards differ, apply HIGHER of the two

What Consolidated CDD Enables:

- Detect patterns across accounts at different subsidiaries
- Identify customer activity that may be low-risk in one region but high-risk in another
- Share information between compliance teams across the enterprise
- Build complete customer risk profile across all products and geographies

[RED FLAG: Boundaries or silos in communication should NOT exist within an institution.]

Required Scope - Operational Effectiveness

Independent testing is one of the five mandatory BSA pillars.

Area	Specific Testing Procedures
Transaction Monitoring	Test thresholds using historical SARs; calculate false negative rate; validate alert logic
Sanctions Screening	Test fuzzy logic; validate name matching; review override decisions
CDD/KYC	Review high-risk samples; verify UBO identification; test EDD documentation
SAR Filing	Review timeliness; assess quality; test escalation; validate no tipping-off
Training	Assess role-based content; test completion rates; evaluate effectiveness
Governance	Review Board approvals; test independence; review escalation documentation

[RED FLAG: Not sufficient: Only reviewing policies without testing transactions.]

Qualification Requirements

The tester must meet specific independence and expertise requirements.

Acceptable	NOT Acceptable
Internal Audit (if independent)	Compliance testing itself
External Audit Firm	Audit that designed controls
Third-Party Consultant	Former compliance staff who designed policies
Independent consultant	Business line employees
No prior involvement	Vendors who built the system

Requirements:

- Independence: No involvement in designing or operating controls
- Expertise: AML/CFT knowledge and qualifications
- Objectivity: No conflicts of interest
- Reporting: Reports to Board or Audit Committee, not CCO

[SCENARIO] Audit Discovers 77 Percent False Negative Rate Auditor tests system by running 500 historical SAR cases through current system. 387 of 500 (77 percent) would NOT generate an alert under current thresholds.

How to Analyze:

- 1 77 percent false negative rate is EXTREMELY high
- 2 System would miss over three-quarters of confirmed suspicious activity
- 3 Operational burden is NOT a valid excuse
- 4 Regulators prioritize detection over efficiency

[TRAP] High alert volume justifies maintaining current thresholds. [CORRECT] System must be effective first. Document deficiency, create remediation plan, recalibrate thresholds.

[SCENARIO] Tester Previously Worked in Compliance Bank hires external consulting firm for AML audit. Firm assigns individual who was bank's BSA Officer until 8 months ago. This individual personally designed several policies now being audited.

How to Analyze:

- 1 Independence is about the PERSON, not just the firm
- 2 Person who designed controls cannot audit those controls
- 3 8-month separation does NOT restore objectivity
- 4 Firm should assign different personnel

[TRAP] Consultant is external, so independence is automatically satisfied. [CORRECT]
Individual tester must have no prior involvement.

[SCENARIO] Audit Reports to CCO for Approval Audit completes annual AML audit and issues draft report identifying deficiencies. Audit manager provides draft to CCO for approval before finalizing. CCO requests that critical findings be removed. Audit manager agrees.

How to Analyze:

- 1 Audit must report findings directly to Board
- 2 Management cannot approve or edit audit findings
- 3 Removing findings destroys audit independence
- 4 Final report is unreliable

[TRAP] CCO is responsible for AML program and should review findings for accuracy.

[CORRECT] Audit findings must be reported directly to Board without management filtering.

How Often Must Testing Be Performed?

Frequency depends on risk profile, but at least annually for most institutions.

Risk-Based Frequency:

- High-risk institutions: Semi-annual or quarterly testing recommended
- Medium-risk institutions: Annual testing is standard
- Low-risk institutions: Annual testing is minimum

Trigger Events for Interim Testing:

- New high-risk products or services
- Significant customer base growth
- Merger or acquisition
- Regulatory enforcement action
- Material system changes
- Emergence of new typologies
- Known control deficiencies

[RED FLAG: Annual is minimum, not maximum.]

Training Must Be Tailored to Specific Roles

Different employees need different training based on their responsibilities.

Role-Based Training Requirements:

- **Tellers:** Cash structuring, CTR triggers, identifying suspicious customer behavior, red flags
- **Relationship Managers:** PEP identification, EDD requirements, red flags, source of wealth
- **Board of Directors:** Governance oversight, risk strategy, regulatory expectations, enforcement trends
- **IT/Technology:** Data security, system controls, audit trail requirements, data quality
- **Compliance Staff:** Advanced investigation techniques, SAR writing, regulatory updates, emerging typologies
- **Senior Management:** Program oversight, resource allocation, escalation procedures, regulatory risk
- **New Hires:** Initial training before any customer contact

[RED FLAG: The same training module delivered to all employees regardless of role is a DEFICIENCY.]

[SCENARIO] Bank Delivers Same Training to All 5,000 Employees Bank delivers same two-hour online AML training module to all employees: tellers, RMs, Board, IT staff. Training covers technical details of transaction monitoring thresholds.

How to Analyze:

- ❶ Tellers need training on cash structuring and CTRs, not model calibration
- ❷ Board members need governance training, not technical threshold details
- ❸ One-size-fits-all training is ineffective

[TRAP] All employees need same training to ensure consistent institutional coverage.

[CORRECT] Training must be tailored to specific roles, responsibilities, and ML/TF risks.

[SCENARIO] Board Training Covers CTR Filing and Alert Review Bank's annual Board AML training covers: how to identify suspicious transactions in alerts and how to file CTRs.

How to Analyze:

- ❶ Board members do NOT file CTRs or review alerts (operational)
- ❷ Board training should cover risk appetite, governance, oversight
- ❸ Operational training is inappropriate for Board

[TRAP] Board members need to understand all aspects of AML program. [CORRECT]
Board training should focus on governance, oversight, risk strategy, and regulatory expectations, not operational tasks.

Training Frequency Requirements

Initial training AND periodic refresher training are required.

Frequency Requirements:

- New hire training: Before any customer contact or within 30 days
- Annual refresher training: At least once per calendar year
- Role change training: When employee moves to new position
- Policy change training: When material changes occur
- Remedial training: For employees who fail testing or make errors

Documentation Requirements:

- Training attendance records (who attended)
- Training content (what was covered)
- Training dates and duration
- Testing results (if applicable)
- Certificates of completion
- Retention: Minimum 5 years

Training Effectiveness Assessment:

- Pre- and post-training testing
- Scenario-based testing
- Observations of employee behavior
- Audit of training program
- Tracking of repeated errors

[RED FLAG: Training without effectiveness assessment may not satisfy regulatory requirements.]

Insiders Pose Same Threat as Customers

Financial institutions have learned that an insider can pose the same money laundering threat as a customer.

Key KYE Controls:

- Background checks on hiring (criminal, credit, employment verification)
- Ongoing employee monitoring (not just customer monitoring)
- Segregation of duties (no single employee controls end-to-end)
- Access controls and audit trails (who accessed what)
- Mandatory vacation policies (detect ongoing fraud)
- Job rotation for sensitive positions
- Employee hotline for reporting suspicious colleagues
- Monitoring for lifestyle changes (where permitted by law)

[RED FLAG: Red flags: Employee living beyond means, refusing vacation, accessing accounts outside job scope, multiple overrides.]

Pre-Employment Screening

Background screening can prevent hiring of statutorily disqualified individuals.

What to Screen:

- Criminal convictions (especially crimes involving dishonesty or money laundering)
- Credit history (where permitted)
- Employment verification
- Education and professional qualifications
- References
- Bankruptcy searches (for sensitive positions)
- ML/TF information sources

Regulatory Prohibitions:

- Persons convicted of crimes involving dishonesty or money laundering may be prohibited from becoming institution-affiliated parties
- Prior written consent of regulator may be required

Ongoing Screening Considerations:

- Periodic fingerprint checks for sensitive positions
- Enhanced screening upon promotion to high-level positions
- Monitoring social media (where permitted by law)

Detecting Insider Misconduct

Employee behavior can indicate complicity in money laundering.

Employee Red Flags:

- Employee exaggerates customer credentials in required reports
- Employee involved in excessive number of unresolved exceptions
- Employee lives lavish lifestyle not supported by salary
- Employee frequently overrides internal controls or circumvents policy
- Employee uses company resources for private interests
- Employee assists transactions where ultimate beneficiary is undisclosed
- Employee avoids taking periodic vacations

Mandatory Vacation as a Control:

- Employee must take consecutive days off (typically 5-10 business days)
- Another employee performs duties during absence
- Substitute may discover irregularities employee was hiding
- Common for wire transfer processors, account opening staff, override approvers

The Core Calibration Trade-Off

Every AML monitoring system faces this fundamental decision.

Term	Definition	Risk
False Positive	Legitimate activity triggers alert	Wasted analyst time; operational inefficiency; analyst fatigue
False Negative	Suspicious activity generates no alert	MISSED criminal activity; direct AML deficiency; enforcement risk

[RED FLAG: Which is worse? FALSE NEGATIVES are significantly worse.] [NOTE:

Regulator Priority: Detection effectiveness & operational efficiency.]

[SCENARIO] Director Raises Thresholds by 250 Percent Bank generates 8,000 alerts/month with 96 percent false positives. Director orders all thresholds raised by 250 percent to reduce costs.

How to Analyze:

- ❶ 250 percent increase is extreme and arbitrary
- ❷ Many suspicious transactions will fall below thresholds
- ❸ Director prioritizing cost over effectiveness

[TRAP] Director correctly managing operational efficiency. [CORRECT] Raising thresholds must be data-driven. Validate new thresholds still detect known typologies.

[SCENARIO] System Generates 50,000 Alerts Per Month Bank sets thresholds very low to catch everything. System generates 50,000 alerts/month. Team has 5 analysts, each can review 200 alerts/month. Backlog grows to 40,000 uninvestigated alerts.

How to Analyze:

- 1 Team can only review 1,000 alerts/month
- 2 49,000 alerts/month are never reviewed
- 3 Unreviewed alerts provide zero detection value

[TRAP] Lower thresholds always better because they catch more activity. [CORRECT]
System must be calibrated so team can review all alerts. Unreviewed alerts are a control failure.

[SCENARIO] Model Performance Degrades Over 3.5 Years Bank deployed ML model January 2022 with 72 percent precision and 81 percent recall. June 2025 validation shows 51 percent precision and 62 percent recall. Bank introduced new products, volumes up 180 percent, typologies shifted.

How to Analyze:

- 1 Models degrade when behavior/products/typologies change
- 2 3.5 years without recalibration is a significant gap
- 3 Annual recalibration or trigger-based retraining required

[TRAP] Model still has recall above 60 percent, which is acceptable. [CORRECT] Bank must establish model monitoring and refresh processes.

Core Concept

A monitoring system is only as good as the data it receives. Missing data = missing alerts.

Critical Controls:

- Reconciliation between source systems and monitoring system (daily)
- Data completeness and accuracy checks (automated validation)
- Error handling for failed data feeds (no silent failures)
- Regular validation that all required transactions are ingested
- Data lineage documentation
- Data quality metrics and reporting to management

[RED FLAG: The worst data failure: Silent failure where data is missing but no error messages alert the team.]

[SCENARIO] 34 Percent of Wires Missing for 14 Months Bank's monitoring system relies on daily feeds from 17 upstream systems. Audit reveals that for 14 months, feed from international wire system silently failed for 34 percent of all wires. Estimated \$340 million in wires not monitored.

How to Analyze:

- 1 34 percent missing data = massive monitoring gap
- 2 No alerts for transactions system never received
- 3 Absence of reconciliation controls is foundational failure
- 4 Bank must remediate AND review missed transactions retrospectively

[TRAP] Misconfiguration was accidental, so no compliance violation. [CORRECT] Bank must have controls to verify complete data ingestion.

Reconciliation Controls - What Must Exist

Banks must be able to prove that all transactions entered the monitoring system.

Reconciliation Methodology:

- Source system transaction count vs. monitoring system intake count (daily)
- Source system total dollar volume vs. monitoring system total volume (daily)
- Hash total comparisons for data integrity
- Exception report for any discrepancies
- Timely resolution of exceptions (24-48 hours)
- Escalation for unresolved exceptions

Common Data Quality Issues:

- Missing transactions (data feed failure)
- Duplicate transactions (processing errors)
- Corrupted data (format issues)
- Delayed data (latency beyond acceptable window)
- Incomplete data (missing required fields)
- Incorrect data (wrong values, mapping errors)

Technology as an Enabler

Manual AML compliance is difficult, if not impossible, for most institutions.

Key Automated Capabilities:

- Automated customer verification using third-party databases
- Watch list filtering (sanctions, PEPs, adverse media)
- Transaction monitoring (scanning and analyzing transactional data)
- Automation of regulatory reporting (SARs, CTRs)
- Case management (dashboard for KYC, history, investigations, filings)
- Audit trail (documenting steps for auditors and supervisors)

Benefits of Automation:

- Increased efficiency and control
- Regulators receive prompt, formatted information
- Reflects commitment to meet/exceed compliance requirements

Request For Proposal (RFP) Method

Many institutions use RFPs to select AML software vendors.

Evaluation Team Composition:

- Management from compliance, operations, technology, and business departments
- Project manager to facilitate
- Team reviews and scores all responses

Key Capabilities to Assess:

- Ability to monitor transactions and identify anomalies
- Ability to gather CDD information and score customer responses
- Advanced evaluation and analysis of suspicious transactions
- View individual alerts within broader customer context
- Workflow features (create cases, collaborate, share information)
- Automated STR preparation and filing
- Standard and ad-hoc reporting
- User-friendly updating of risk parameters
- Tiered user-rights access

Case Management as Central Hub

Effective case management is critical for investigations and audit trails.

Case Management Features:

- Dashboard view of all investigations by analyst
- Centralized customer KYC and transaction history
- Link multiple alerts to single case
- Document management for investigation findings
- Track SAR/STR filings by customer
- Supervisor approval workflow
- Audit trail of all case actions
- Reporting on investigation volume and outcomes
- Aging reports for open cases

Documentation Management:

- Imaging systems for paperless access to records
- Track missing or expired documents
- One-stop access to images and compliance documents

FATF Recommendation 15 - New Technologies

Countries and financial institutions must assess ML/TF risks of new products prior to launch.

Risk Questions for New Products/Services:

- Does the product enable significant volumes of transactions rapidly?
- Does it allow customers to engage with minimal oversight?
- Does it afford significant anonymity to users?
- Does it have an especially high transaction or investment value?
- Does it allow payments to third parties?
- Does it have unusual complexity?

High-Risk Products (Examples):

- Private banking, offshore international activity
- Wire transfer and cash management functions
- Prepaid cards, mobile payments, internet-based payment services
- Trade financing with unusual pricing features
- Payable Through Accounts (PTAs)

[RED FLAG: Compliance officer must be active participant in new product project teams.]

Core Concept

Different analysts should reach similar conclusions on similar facts. Wide variation indicates lack of standards.

Required Controls for Consistency:

- Written adjudication guidelines for each scenario
- Required documentation standards
- Quality assurance reviews of closed alerts
- Calibration sessions to align analyst judgment
- Supervisor approval for certain dispositions
- Appeal process for disputed decisions
- Regular training on adjudication standards

[RED FLAG: One analyst closes 95% of alerts; another escalates 70% for the same scenario.]

QA Program - Essential Elements

Quality assurance is the check on analyst decision-making.

QA Program Components:

- Sample size: Sufficient to be statistically valid (typically 5-10% of alerts)
- Sampling methodology: Random plus targeted (high-risk scenarios, specific analysts)
- QA reviewer independence: Different from original analyst
- QA reviewer qualifications: More experienced than front-line analysts
- Dispute resolution process
- Remediation process for errors
- Trending of QA findings over time
- Monthly reporting to compliance management

What QA Reviews:

- Did analyst obtain required documentation?
- Is documentation sufficient to support conclusion?
- Was analysis thorough and logical?
- Was conclusion reasonable based on evidence?
- Were escalation procedures followed?
- Was SAR filed when required?
- Was tipping-off avoided?

[RED FLAG: No QA program = no assurance that analysts are making correct decisions.]

Core Concept

SARs must be filed immediately upon suspicion, regardless of transaction value.

Key Principles:

- Legal standard = REASONABLE SUSPICION (not certainty, not probable cause)
- No minimum monetary threshold for money laundering suspicion
- Do NOT delay filing to gather more evidence
- File first, continue investigating if needed
- Cannot consider commercial impact of filing
- Cannot notify customer (tipping-off prohibition)

What Reasonable Suspicion Means:

- More than a hunch, less than probable cause
- Specific articulable facts suggesting possible money laundering
- Based on training, experience, and available information
- Does not require knowledge of underlying predicate offense

[RED FLAG: We need more evidence before filing - this is INCORRECT. Reasonable suspicion is enough.]

Weighing Aggravating and Mitigating Factors

The decision to file an STR results from accumulation of aggravating factors and lack of mitigating factors.

Aggravating Factors:

- Structuring transactions below reporting thresholds
- Unexplained wire transfers to/from high-risk jurisdictions
- Transactions inconsistent with customer's stated business
- Customer reluctance to provide information
- Negative media or law enforcement inquiries
- Multiple alerts on same customer

Mitigating Factors:

- Documentation supporting legitimate explanation
- Consistency with known business activities
- Historical pattern of similar activity (not suspicious)
- Customer cooperation with RFIs

Documentation Requirement:

- The decision NOT to file is as important as the decision to file
- Document reasoning for both outcomes

Oversight of Investigations Process

Institutions must have robust policies for oversight of regulatory reporting.

Escalation Triggers:

- Customer-facing employee complicity in suspicious activity
- Compliance chain-of-command willful blindness
- Significant reputational risk to institution
- Pattern of filings indicating systemic issue
- Potential insider involvement

Reporting to Senior Management/Board:

- Number of STRs filed (dollar amounts, trends)
- Significant compliance deficiencies identified
- Law enforcement inquiries related to filings
- Emerging typologies observed

Quality Assurance of STRs:

- STR quality indicates quality of AML program
- QA ensures internal consistency
- QA reviewers must be qualified and independent

Closing the Account - Independent Determination

Based on internal investigation, institution decides whether to close account.

Factors to Consider:

- Legal basis for closing account
- Institution's policies (e.g., automatic closure after specified number of STRs)
- Seriousness of underlying conduct
- Reputational risk to institution if account maintained
- Law enforcement requests (to close OR maintain account)

What NOT to Do When Closing:

- Do NOT tell customer reason if related to SAR (tipping-off)
- Do NOT close account to retaliate against whistleblower customer
- Do NOT close account without documentation
- Do NOT delay returning customer funds

Alternatives to Full Closure:

- Restrict account activity (no wires, no new deposits)
- Enhanced monitoring
- Lower transaction limits
- Require prior approval for certain transactions

STRs as Financial Intelligence

Following STR filing, additional law enforcement notification may be warranted.

When to Proactively Notify Law Enforcement:

- Activity involves imminent threat
- Activity is time-sensitive
- Law enforcement has previously expressed interest in subject
- Filing may be lost in high-volume of reports

When Law Enforcement Contacts Institution:

- May seek underlying information used in investigation
- Institution should have policy for responding
- Designate specific personnel for LE communication
- Document all LE contacts and information provided

Critical:

- Do NOT disclose STR filing to customer
- Do NOT confirm or deny existence of STR
- Cooperate as permitted by law

Proactive and Reactive Investigation Sources

Investigations may be initiated from multiple channels.

Common Investigation Initiators:

- Regulatory recommendations or official findings
- Transaction monitoring rules (automated alerts)
- Referrals from customer-facing employees (branch personnel, RMs)
- Internal hotlines (ethics, compliance, whistleblower)
- Negative media information about customer
- Receipt of governmental subpoena or search warrant

Referral Mechanisms:

- Online forms for branch personnel to report unusual activity
- Dedicated AML/CFT compliance email address
- Training on what constitutes a referral

Internal Hotlines:

- Allow anonymous reporting of employee fraud, code violations, suspicious activity
- Prohibition against retaliation for reporting

Effective Financial Investigation Steps

Main objective: track movement of money.

Investigation Steps:

- 1 Review internal transactions, customer information, internal documentation
- 2 Identify and review external information (internet, public records, media)
- 3 Contact business line employees responsible for account relationship
- 4 Generate written report documenting relevant findings

Internal Records to Review:

- Signature cards, account statements, deposit tickets, checks
- Loan records, cashier's checks, traveler's checks, money orders
- Wire transfer records, safe deposit box records
- Login activity logs, IP addresses (online banking)

Retention Requirements:

- Typically 5 years for customer account records

Using the Internet for Investigations

External information provides context for internal records.

Reliable Internet Sources:

- FATF, Wolfsberg, OECD, OFAC websites
- Supervisory authority websites (regulators)
- Corporate registrars, electoral rolls
- Court lists, judicial decisions, administrative tribunals
- Professional oversight bodies (law societies)

Caution with Media Sources:

- Journalists have biases
- In some countries, press is not free
- Verify from multiple sources
- Consider source's reliability

Search Tips:

- Prepare plan before searching
- Use multiple search engines (no single engine covers entire web)
- Use metasearch engines
- Use local search engines for foreign countries
- Consider commercial databases (fee-based, cross-reference many records)

Mandatory Record Retention

Financial institutions must retain specified records for minimum periods.

Core Retention Requirements:

- Account opening records (CIP/KYC): 5 years after account closing
- Transaction records: 5 years from transaction date
- SAR filings and supporting documentation: 5 years from SAR filing date
- CTR filings: 5 years from filing date
- Funds transfer records (over \$3,000): 5 years
- Suspicious activity investigation records (even if no SAR filed): 5 years
- Training records: 5 years (track completions, content, dates)
- Independent testing reports: 5 years
- Board meeting minutes (AML-related): Permanent

What "5 Years" Means:

- Five years from the date of the last activity or filing
- For SARs: five years from SAR filing date
- Electronic records must be accessible and readable for full period

[RED FLAG: Deleting records before retention period expires is a violation.]

Core Concept

RFIs are formal requests sent to customers asking for clarification or documentation.

Best Practices for RFIs:

- Use when you need more information to resolve an alert
- Document the RFI and any response (or lack thereof)
- Do NOT disclose that an investigation or SAR is pending (tipping-off)
- Failure to respond is itself a red flag
- Set reasonable deadline (typically 5-10 business days)
- Escalate if no response received

[RED FLAG: RFIs must be phrased neutrally. Do NOT say "we are investigating you for money laundering."]

[SCENARIO] Analyst Tells Customer About AML Flag Compliance analyst calls customer: Our AML system flagged your deposits as potential structuring. We need to know where you are getting all this cash, or we might have to file a report.

How to Analyze:

- 1 Mentioning AML system and potential structuring is tipping-off
- 2 Mentioning "file a report" is explicit tipping-off
- 3 Customer now knows they are under investigation

[TRAP] Analyst was honest with customer, which is good customer service. [CORRECT]
RFIs must be neutral. Example: "We noticed increase in cash deposits. Can you provide documentation explaining source of funds?"

Examples of Proper RFI Wording

Neutral language that does not tip off the customer.

Proper Wording Examples:

- "We noticed an increase in wire transfers from your account. Please provide documentation explaining the business purpose."
- "Please confirm the nature of your relationship with [counterparty] and provide any supporting agreements."
- "Our records show cash deposits totaling [amount] over [period]. Please provide documentation supporting the source of these funds."

When to Escalate Without RFI:

- Sending RFI would tip off customer (suspicion is very strong)
- Customer has history of destroying records when asked
- Law enforcement requests no contact
- Immediate SAR filing is more appropriate

[SCENARIO] Teller Tells Customer About Compliance Review Customer asks teller why wire transfer is delayed. Teller says: "Our compliance team is reviewing your account for some unusual activity."

How to Analyze:

- 1 Tipping-off includes disclosing that an investigation EXISTS
- 2 You do NOT need to mention SAR by name to tip off
- 3 Telling customer they are under compliance review IS tipping-off
- 4 Violation occurred even though no SAR filed yet

[TRAP] No SAR was filed yet, so no tipping-off occurred. [CORRECT] Tipping-off includes disclosing existence of internal investigation.

Unauthorized Disclosure is a Crime

Disclosing SAR information without authorization carries criminal penalties.

Penalties for Unauthorized Disclosure:

- Criminal fines up to \$250,000 for individuals
- Imprisonment up to 5 years
- Civil penalties for institutions
- Termination of employment

Who Can Receive SAR Information:

- FinCEN and other FIUs (by filing)
- Law enforcement (via proper channels)
- Other opted-in 314(b) institutions (limited)
- Legal department (internal need-to-know)
- Compliance management (internal need-to-know)
- Internal Audit (internal need-to-know)
- Board of Directors (oversight)

Core Concept

Laws protect employees who report AML violations from retaliation.

Key Protections (United States):

- Bank Secrecy Act (31 U.S.C. Section 5328) prohibits retaliation for reporting BSA violations
- Dodd-Frank Act Section 922
- FIRREA (financial institution anti-retaliation)
- Sarbanes-Oxley Act (public company whistleblowers)

What Constitutes Retaliation:

- Termination or firing
- Demotion or reduction in responsibilities
- Suspension without pay
- Harassment or hostile work environment
- Negative performance reviews (PIPs) without prior issues
- Exclusion from meetings or opportunities

[RED FLAG: Retaliation can result in significant damages and reinstatement.]

[SCENARIO] Analyst Receives PIP After Internal Report Compliance analyst reports internally that senior management is suppressing SAR filings on high-revenue corporate client. Three weeks later, analyst receives performance improvement plan citing communication issues - her first negative review in eight years.

How to Analyze:

- 1 Timing (3 weeks after report) suggests retaliation
- 2 First negative review in 8 years is suspicious
- 3 BSA prohibits retaliation for reporting BSA violations
- 4 She can file complaint with DOL/OSHA within 180 days
- 5 Internal reports are protected, not just external

[TRAP] Internal reports are not protected; only external reports to FinCEN are protected.

[CORRECT] BSA prohibits retaliation for internal reports as well.

AML Compliance Does Not Operate in Isolation

Other departments enable effective AFC programs.

Key Supporting Functions:

- Data Privacy: Ensures customer data protected while enabling lawful information sharing
- Cybersecurity: Protects AML systems from attack; identifies cyber-related red flags
- IT/Technology: Maintains transaction monitoring systems, data feeds, audit trails
- Human Resources: Employee due diligence, insider threat monitoring
- Vendor Management: Third-party due diligence for outsourced AML functions
- Legal: Advice on regulatory requirements, subpoena response
- Internal Audit: Independent testing of AML controls (Third Line)
- Risk Management: Enterprise risk assessment integration

[RED FLAG: AML cannot function effectively without strong support from these departments.]

[SCENARIO] Bank Receives GDPR Right to Erasure Request European bank receives GDPR right to erasure request from customer demanding deletion of all personal data. Customer was subject of SAR filed 18 months ago.

How to Analyze:

- 1 GDPR Article 17(3) exempts data retention required by law
- 2 AML recordkeeping (minimum 5 years) is legal obligation
- 3 Bank can lawfully refuse to delete AML-required records
- 4 SAR confidentiality also prohibits acknowledging SAR to customer

[TRAP] GDPR right to erasure is absolute and overrides all other laws. [CORRECT] AML retention requirements are legal exception to GDPR erasure.

IT's Role in AML Compliance

IT maintains the systems that enable AML monitoring. Failures become compliance failures.

IT Responsibilities for AML:

- System availability (monitoring must run 24/7/365)
- Data integrity (no corruption, accurate processing)
- Audit trails (who accessed what, when, from where)
- Change management (documented approvals for system changes)
- Disaster recovery (backup systems, recovery time objectives)
- Security (access controls, preventing unauthorized changes)
- Performance (system processes alerts within required timeframes)

[RED FLAG: IT failures are compliance failures when they impact AML monitoring effectiveness.]

Bank Remains Responsible for Outsourced Functions

Vendor risk must be managed. Bank retains ultimate regulatory responsibility.

Key Requirements:

- Due diligence on vendors before engagement
- Contractual obligations for AML compliance
- Right to audit vendor performance
- Ongoing monitoring of vendor effectiveness
- Bank retains ultimate regulatory responsibility
- Cannot outsource accountability

Vendors Requiring AML Due Diligence:

- Transaction monitoring system providers
- Sanctions screening vendors
- KYC/CIP verification services
- Case management system providers
- Training providers
- Independent testing firms

[RED FLAG: Cannot outsource responsibility: Bank is still accountable to regulators.]

[SCENARIO] Vendor System Fails for 8 Months Bank outsources transaction monitoring to third-party vendor. Vendor system fails to generate alerts for 8 months due to technical error. Bank's internal compliance team did not perform any validation of vendor outputs.

How to Analyze:

- 1 Bank is ultimately responsible to regulators
- 2 Bank cannot delegate liability to vendor
- 3 Bank should have performed validation and reconciliation
- 4 Bank must remediate (review missed period, file SARs)

[TRAP] Vendor contract makes them liable for monitoring failures. [CORRECT] Bank retains regulatory responsibility regardless of vendor contracts.

Pre-Engagement and Ongoing Vendor Diligence

Comprehensive due diligence required before and during vendor relationship.

Pre-Engagement Due Diligence:

- Vendor background and reputation
- Financial stability
- Vendor's own AML program
- Data security practices
- References from other bank clients
- Regulatory history (enforcement actions)
- Business continuity and disaster recovery

Contract Requirements:

- Right to audit vendor (on-site and remote)
- Service level agreements (uptime, accuracy)
- Data ownership and return provisions
- Breach notification requirements
- Liability and indemnification provisions

When Customer Poses Unacceptable Risk

Bank must escalate through governance and potentially offboard.

Escalation Path for High-Risk Customers:

- 1 Analyst identifies suspicious activity
- 2 Investigation conducted and documented
- 3 If SAR filed, notify AML committee
- 4 If multiple SARs or high risk, escalate to senior management
- 5 Board notification for material risks
- 6 Decision to offboard requires senior management approval

Documentation Required:

- Summary of suspicious activity
- Investigation findings
- SARs filed (if any)
- Risk assessment of relationship
- Attempts to remediate (RFIs, enhanced monitoring)
- Recommendation (close or continue)

[SCENARIO] Bank Has Filed 7 SARs on Account Over 14 Months Bank filed 7 SARs on account over 14 months. Account shows clear patterns of structured deposits followed by wires to offshore shell companies. RM argues: No conviction has occurred. Client is innocent until proven guilty.

How to Analyze:

- ❶ Banks are not courts of law
- ❷ Standard for offboarding is risk, not conviction
- ❸ 7 SARs on one account is clear evidence of elevated risk
- ❹ Bank can (and often should) offboard

[TRAP] Customer is innocent until proven guilty, so bank should keep account. [CORRECT]
Offboarding is risk management decision, not criminal conviction.

All Topics Now Covered for Domain C (30% of Exam)

The following topics have been covered in this presentation:

- Three Lines of Defense
- Board governance and minutes
- CCO independence and authority
- Adequate resources requirement
- Enterprise-Wide Risk Assessment (EWRA)
- Risk scoring models
- Dynamic customer risk reassessment
- Customer Due Diligence (CDD) - 4 elements
- Beneficial ownership verification
- Consolidated CDD
- Enhanced Due Diligence (EDD)
- PEP requirements
- Account opening procedures
- Independent testing requirements
- Training (role-based)
- Know Your Employee (KYE)
- Insider threat red flags
- Transaction monitoring calibration
- Data quality and reconciliation
- Automated AML solutions
- New product risk assessment
- Alert adjudication and QA
- SAR filing standard (reasonable suspicion)
- STR decision-making process
- Account closure decisions
- Law enforcement communication
- Investigation sources and conduct
- Internet investigation tips
- Recordkeeping requirements
- RFIs (neutral wording)
- Tipping-off prohibition
- Whistleblower protections
- Supporting departments (IT, privacy, cybersecurity)
- Vendor due diligence
- Escalation and offboarding

[NOTE: This completes coverage of all Domain C topics for the CAMS exam.]

- 1 Three Lines: First=Business, Second=Compliance, Third=Audit
- 2 Independence: Audit cannot design controls it later tests
- 3 Board approves program, CCO implements
- 4 False negatives worse than false positives
- 5 Risk assessment = foundation of program
- 6 CDD has four elements (identify, verify, understand, monitor)
- 7 Beneficial owner = natural person with control
- 8 EDD required for PEPs and high-risk customers
- 9 Training must be role-based, not one-size-fits-all
- 10 Independent testing must be truly independent
- 11 Silent data failure = monitoring gap
- 12 Alert adjudication must be documented
- 13 SAR standard = reasonable suspicion
- 14 Tipping-off includes disclosing investigation exists
- 15 RFIs must be neutral phrasing
- 16 Whistleblower protections exist for internal reports
- 17 Vendor oversight: bank retains responsibility
- 18 Offboarding is risk decision, not conviction
- 19 Insider threats: monitor employees
- 20 Mandatory vacation detects fraud
- 21 RMs cannot block SARs for commercial reasons
- 22 GDPR has AML retention exception
- 23 Data reconciliation prevents silent failures
- 24 QA reviews ensure analyst consistency
- 25 Senior management faces personal liability
- 26 Board must be informed of material deficiencies
- 27 Training without effectiveness assessment is insufficient
- 28 New products require pre-launch risk assessment
- 29 Record retention = 5 years minimum
- 30 Under-resourcing is NOT a defense

- Domain C is 30 percent of exam - second largest domain
- Three Lines of Defense is foundational - know who does what
- Independence is critical - audit cannot audit its own work
- SAR standard = reasonable suspicion, not proof
- Tipping-off includes disclosing investigation exists
- False negatives are worse than false positives
- Training must be role-based
- Whistleblower protections exist for internal and external reports
- Banks cannot outsource regulatory responsibility to vendors
- Offboarding is risk decision, not conviction
- RMs cannot override compliance SAR decisions
- Board must approve AML program
- Material deficiencies must be reported to Board
- RFI must be neutral - cannot mention AML or filing
- Data reconciliation prevents silent feed failures
- QA ensures analyst consistency
- Mandatory vacation detects insider fraud
- CCO cannot approve their own program - Board approval required